Засоби реалізації політики інформаційної безпеки. Міжмережеві екрани.

Архітектура ІКС і кібербезпека 1
Принципи розділення ІКС на домени безпеки 1
Засоби сегментації та сегрегації 3
Функції міжмережевих екранів 4
Пакетна фільтрація 5
Трансляція IP-адрес 8

Архітектура ІКС і кібербезпека

При розробці архітектури мережі для розгортання ІКС зазвичай рекомендується відокремити власну ІКС від ніших мереж, в яких характер мережевого трафіку відрізнється. Суворі процедури контролю змін для мережевого обладнання, конфігурації та змін програмного забезпечення можуть не застосовуватися в корпоративній мережі. Якщо мережевий трафік ІКС передається в зовнішню мережу, він може бути перехоплений або підданий атакам DoS або Man-in-the-Middle. За наявності окремих мереж, проблеми безпеки та продуктивності в зовнішній мережі не повинні впливати на мережу ІКС.

З'єднання з зовнішніми мережами становить значну загрозу безпеці і має бути захищене пристроями захисту кордонів. Якщо мережі необхідно підключити, рекомендується дозволяти лише мінімальні (якщо можливо одиничні) з'єднання, при чому з'єднання здійснюватиметься через міжмережевий екран (брандмауер, фаєрволл) та через так звану демілітаризовану зону DMZ (див. далі). Сервери, що містять дані з ІКС, до яких необхідно отримати доступ з мереж, які належать іншим доменам безпеки, розміщуються в цьому сегменті мережі. Тільки ці системи повинні бути доступні з інших доменів безпеки. З будь-якими зовнішніми підключеннями має бути дозволений мінімальний доступ через брандмауер, включаючи відкриття лише портів протоколів транспортного рівня, необхідних для певного інформаційного обміну.

Принципи розділення ІКС на домени безпеки

Першим і найважливішим етапом побудови кібербезпеки ІКС є розподіл системи на окремі домени безпеки, в яких можливо мати єдину політику, однакові повноваження управління елементами, однаковий рівень довіри. Розподіл може бути за різними ознаками, наприклад використання в системі певного типового обладнання, якому властиве схоже середовище загроз і ризиків. Потім такі домени необхідно відокремити один від одного за рахунок сегментації, мережі розділити на менші підмережі.

Термін «сегрегація» який використовують в іноземній літературі, буквально означає застосування політики примусового відокремлення з подальшою дискримінацією прав. Це влучна аналогія, бо відокремлення має відбуватись шляхом і фізичного сегментування мережі, і керування інформаційним обміном за принципом максимального обмеження: забороненно має бути все, окрім явно описаних видів інформаційного обміну, які дозволено.

Необхідною, але не достатньою вимогою сегрегації є відокремлення мережі з публічно доступними серверами (в тому числі сервер корпоративної електронної пошти, вебсайт тощо) має бути відокремлена від офісної, а мережа керування технологічними процесами – від всіх інших сегментів мережі.

Метою сегментації та сегрегації є знаходження балансу між мінімізацію доступу до чуттєвої інформації з боку систем та осіб, яким вона непотрібна для виконання власних функцій, та чіткої впевненості, що накладені обмеження дійсно не зашкоджують виконанню цих функцій і в цілому ефективній роботі підприємства. Ця стратегічна мета вирішується через послідовні тактичні кроки, які мають звести до мінімуму різномаїття методів доступу та рівнів доступу.

Наведено чотири основні завдання, заради вирішення яких виконується сегментація та сегрегація.

Завдання 1. Розділення та засоби контролю обміну інформацією мають бути присутніми за можливості на всіх рівнях системи, починаючи з фізичного.

Завдання 2. Використовувати принципи найменших привілеїв і найменшої потреби в отриманні інформації.

Завдання 3. Розділити інформацію та інформаційну інфраструктуру на основі вимог безпеки. Найважливіші компоненти вимагають більш суворої ізоляції від інших компонентів.

Завдання 4. Відштовхуватись від парадигми «все заборонено». Це означає, що для інформаційного обміну повинні визначатись конкретні дозволи, замість конкретних заборон (білі списки замість чорних).

Традиційно сегментація та сегрегація мережі реалізуються на шлюзі між мережевими доменами. Середовища ІКС часто мають кілька чітко визначених доменів, таких як робочі локальні мережі, локальні мережі керування та робочі DMZ, а також шлюзи до менш надійних доменів, таких як Інтернет та інші корпоративні локальні мережі. Якщо розглядати інсайдерські атаки, соціальну інженерію, мобільні пристрої та інші вразливості та сприятливі умови, захист шлюзів домену є розумним і заслуговує на увагу.

Сегрегація мережі передбачає розробку та застосування набору правил, що контролюють які комунікації дозволені через кордон між мережами. Правила, зазвичай, засновані на ідентифікаторі джерела та призначення, а також на типі чи вмісті даних, що передаються.

При правильному застосуванні сегментації та сегрегації мережі ви мінімізуєте методи і рівні доступу до конфіденційної інформації. Цього можна досягти за допомогою різноманітних технологій і методів. Залежно від архітектури та конфігурації вашої мережі, деякі з поширених технологій і методів, що використовуються, включають:

- Логічне розділення мережі, що забезпечується шифруванням або розділенням мережевим пристроєм.
  - Віртуальні локальні мережі (VLAN).
  - Зашифровані віртуальні приватні мережі (VPN) використовують криптографічні механізми для розділення трафіку, об'єднаного в одній мережі.
  - Односпрямовані шлюзи обмежують зв'язок між з'єднаннями в одному напрямку, таким чином, сегментуючи мережу.
- Фізичне розділення мережі для повного запобігання будь-якому взаємозв’язку трафіку між доменами.
- Фільтрування мережевого трафіку, яке може використовувати різноманітні технології на різних рівнях мережі для забезпечення вимог безпеки та доменів.
  - Фільтрування мережевого рівня, яке обмежує, які системи можуть спілкуватися з іншими в мережі на основі IP-адреси та інформації про маршрут.
  - Фільтрація на основі стану, яка обмежує, які системи можуть спілкуватися з іншими в мережі на основі їх призначеної функції або поточного стану роботи.
  - Фільтрація на рівні порту та/або протоколу, яка обмежує кількість і тип послуг, які кожна система може використовувати для зв'язку з іншими в мережі.
  - Фільтрація на рівні застосунків, яка зазвичай фільтрує вміст комунікацій між системами на прикладному рівні. Це включає брандмауери прикладного рівня, проксі та фільтрування на основі вмісту.

Незалежно від технології, обраної для реалізації сегментації та сегрегації мережі, існують чотири загальні думки, які реалізують концепцію глибокого захисту, забезпечуючи хорошу сегментацію та сегрегацію мережі:

- Застосування технології не тільки на мережевому рівні. Кожна система та мережа повинні бути сегментовані та відокремлені, де це можливо, від канального рівня передачі даних до рівня застосунків включно.
- Використання принципи найменших привілеїв і найменшої потреби в отриманні інформації. Якщо системі не потрібно спілкуватися з іншою системою, їй не слід дозволяти. Якщо системі потрібно спілкуватися лише з іншою системою за певним портом чи протоколом і нічого більше – або їй потрібно передавати обмежений набір даних із мітками чи фіксованим форматом, її слід обмежити саме таким чином.
- Розподіл інформації та інфраструктури на основі вимог безпеки. Це може включати використання різного обладнання або платформ на основі різних середовищ загроз і ризиків, в яких працює кожна система або сегмент мережі. Найважливіші компоненти вимагають більш суворої ізоляції від інших компонентів. На додаток до розділення мережі, для досягнення необхідної ізоляції можна використовувати віртуалізацію.
- Впровадження парадигми «білих списків» замість «чорних списків», тобто надати доступ відомим гарним, а не забороняти доступ відомим поганим. Бажано, щоб набір програм, які запускаються в ІКС, був статичними, що робить створення білого списку більш практичним. Це також покращить здатність організації аналізувати файли журналів.

Засоби сегментації та сегрегації

Для обміну інформацією між двома різними мережами необхідно забезпечити для них точку взаємоз‘єднання. В загальному випадку в цьому місці розташовується мережеве обладнання з принаймні двома мережевими інтерфейсами. Це може бути маршрутизатор або більш інтегрований пристрій, який крім маршрутизації реалізовує деякі важливі компоненти політики обміну інформацією між мережами.

Поняття ***шлюзу*** (gateway) виникло як узагальнення функцій обміну даними між мережами в одному пристрої. На відміну від маршрутизатора, мережевий шлюз може працювати на будь-яких рівнях моделі OSI. В інтернет-технологіях відомі і досить використовувані шлюзи, які взагалі не реалізують передачу пакетів (на мережевому рівні), а працюють на рівні застосувань (application level). Найпоширеніші приклади – HTTP Proxy-сервер або SMTP-сервер.

Бастіон-хост (bastion host) – назва сервера, який є шлюзом між локальною мережею та „зовнішнім світом” – Інтернетом. Як правило, його функції – посередництво на рівні застосувань. Але він може виконувати також функції маршрутизатора, якщо встановлений у відповідне місце у мережі. Оскільки через нього встановлюються більшість зв‘язків між внутрішньою та зовнішньою мережею, його безпеці приділяють найбільшу увагу.

В подальшому матеріалі поняття *внутрішньої мережі* буде використовуватись для мережі, що має бути захищена, а поняття *зовнішньої мережі* – Інтернет взагалі.

Мережа-періметр, або демілітаризована зона (DMZ) – це додаткова підмерережа між внутрішньою та зовнішньою мережами. Мета її застосування – розміщення бастіонів та збільшення кількості „рівнів захисту”.

Міжмережевий екран (MME, брандмауер, firewall) – набір компонентів мережевої безпеки, завдання якого обмежити обмін інформацією (чи „доступ”) між внутрішньою та зовнішньою мережами. Поняття міжмережевого екрану включає в себе такі технології (але не лише їх), як фільтрація пакетів, трансляція адрес (NAT), посередництво (proxying).

Для кращого розуміння типових застосувань наведених вище понять, на рис. 1 наведено декілька логічних схем підключення комп‘ютерних мереж.

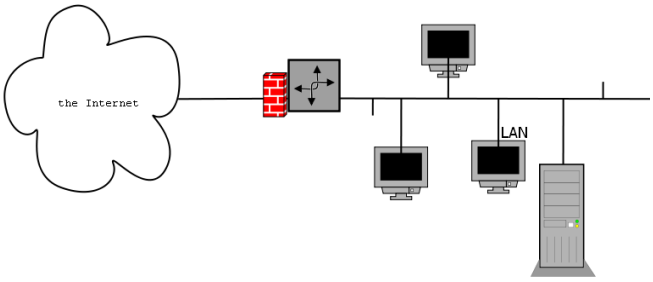
Функції міжмережевих екранів

Поняття міжмережевого екрану (ММЕ), або ***firewall***, може включати в себе різні функції та різну апаратну базу.

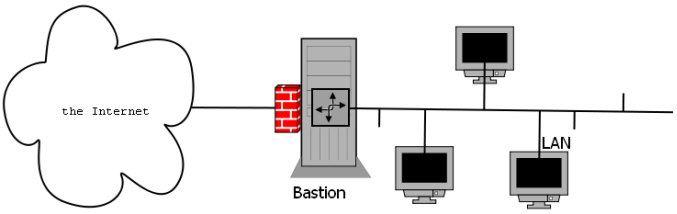
На даний час функції firewall присутні в більшості інтегрованих пристроїв, перш за все класу SOHO (small office/home office – тобто призначений для маленького офісу, не підприємства). Але для більших мереж також виробляються спеціалізовані пристрої. Роздивимось функції та критерії, за якими можна долучити пристрій до певного класу.

Продуктивність апаратного firewall має задовольняти пропускну здатність міжмережевого з‘єднання, яке він обслуговує.

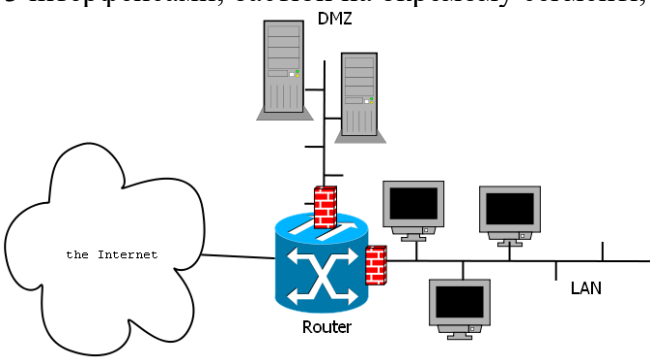
а) маршрутизатор, внутрішня мережа:



б) бастіон з 2 інтерфейсами, внутрішня мережа:



в) маршрутизатор з 3 інтерфейсами, бастіон на окремому сегменті, внутрішня мережа:



г) маршрутизатор з 2 інтерфейсами, бастіон в DMZ, маршрутизатор в DMZ, внутрішня мережа:

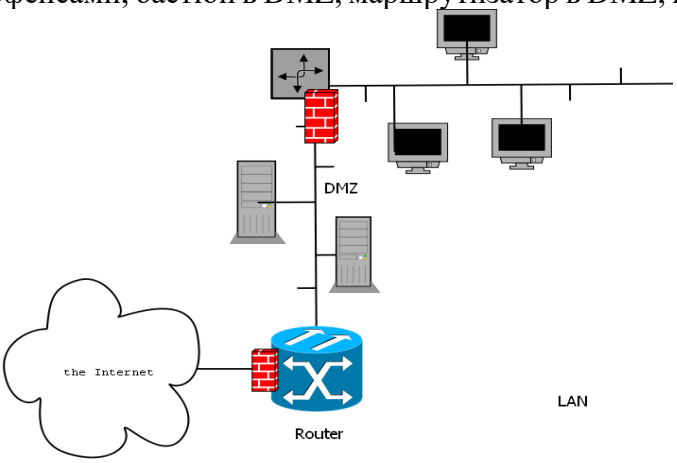


Рисунок 1. Схеми підключення комп‘ютерних мереж із застосуванням різних технологій розмежування

Пропускна здатність сучасного продукту для рівня корпоративної мережі складає 2-4 Гбіт/с в режимі обмеженні несанкціонованого доступу (тобто власне захисту – фільтрації пакетів, тощо). Система фільтрації трафіку має бути контекстною (Stateful Dynamic Packet Filtering), це ускладнює алгоритми та вимагає більшого обсягу пам‘яті, який потрібний для зберігання даних про кожне з‘єднання, встановлене через firewall.

Керованість апаратного firewall також є важливим критерієм. Адміністратор мережі має бути впевненим, що засоби firewall дозволять йому задати налаштунки компонентів захисту необхідного рівня складності за розумний час, тобто інтерфейс адміністратора також є важливим.

Масштабованість (чи ступінь масштабованості) не є обов‘язковим критерієм, але дедалі набирає впливу через загальну тенденцію до різкого зростання інтернет-трафіку в мережах, особливо таких, де керування доступом користувачів до глобальних ресурсів базується на ліберальних засадах. Також масштабованість та можливість централізованого керування бажана для рішень, які обираються для мереж із зростаючим власним контентом (великі веб-портали, датацентри).

Програмні продукти класу firewall повинні базуватись на сервері із стандартною операційною системою, яка також потребує захисту і має бути вдосконалена та додатково налагоджена для використання у якості платформи для firewall. Апаратні рішення firewall, на відміну від суто програмних, в загальному випадку позбавлені цього недоліку, бо базуються на спеціально підготовлених та налаштованих (а інколи – спеціально розроблених) операційних системах.

Пакетна фільтрація

Згадаємо, що пакет є одиницею передавання даних на мережевому рівні. А головна мета створення мережевого рівня полягала в застосуванні механізму маршрутизації.

Фільтрація пакетів (*packet filtering*) є механізмом мережевої безпеки, який на рівні маршрутизатора дозволяє контролювати трафік, що поступає до мережі та виходить з неї. Тому функції фільтрації пакетів зазвичай виконує маршрутизатор – мережевий пристрій який має два чи більше мережевих інтерфейси та забезпечує взаємодію двох чи більше мережевих сегментів без їхнього об‘єднання в єдину ЛОМ.

Якщо маршрутизатор реалізує функцію фільтрації пакетів, то, крім прийняття звичайних рішень „куди передати пакет”, він приймає рішення „чи треба передавати пакет”. Якщо перші рішення приймаються на основі таблиці маршрутизації, то останні – на основі таблиці фільтрації пакетів.

В багатьох випадках фільтрація пакетів виконується без маршрутизації. Це стосується кінцевих комп‘ютерів та мережевих пристроїв, які за допомогою пакетної фільтрації захищають дані та сервіси, що вони виконують. Але лише виконання пакетної фільтрації на маршрутизаторі надає можливість контролювати політику обміну між мережами в одному місці, незалежно від кількості хостів в сусідніх мережах та їхнього підпорядкування.

Надалі мережі, що розподілені маршрутизатором з функціями фільтрації пакетів, будуть мати назву „зовнішня” та „внутрішня”.

Інтуїтивно зрозуміло, що фільтрація на рівні мережевих пакетів відрізняється від фільтрації на рівні вищіх протоколів. Найголовніша відмінність в тому, що пакетна фільтрація працює значно швидше і продуктивніше, бо має справу з невеликими блоками даних приблизно однакового розміру.

Операції з трафіком, які не потребують знання протоколів рівня застосувань, відслідковування сеансів, набагато швидше виконуються пакетними фільтрами. І навпаки,

задачі захисту на рівні протоколів мережевих сервісів краще виконувати за допомогою шлюзів вищих рівнів.

Крім того, деякі задачі захисту можуть бути вирішені виключно засобами пакетної фільтрації, починаючи з елементарної підробки ip-адрес. Приклад – блокування атаки типу forged address, коли пакети з зовнішньої мережі мають підроблену адресу відправника (source address), видаючи себе за пакети з внутрішньої мережі (рис. 2.2).

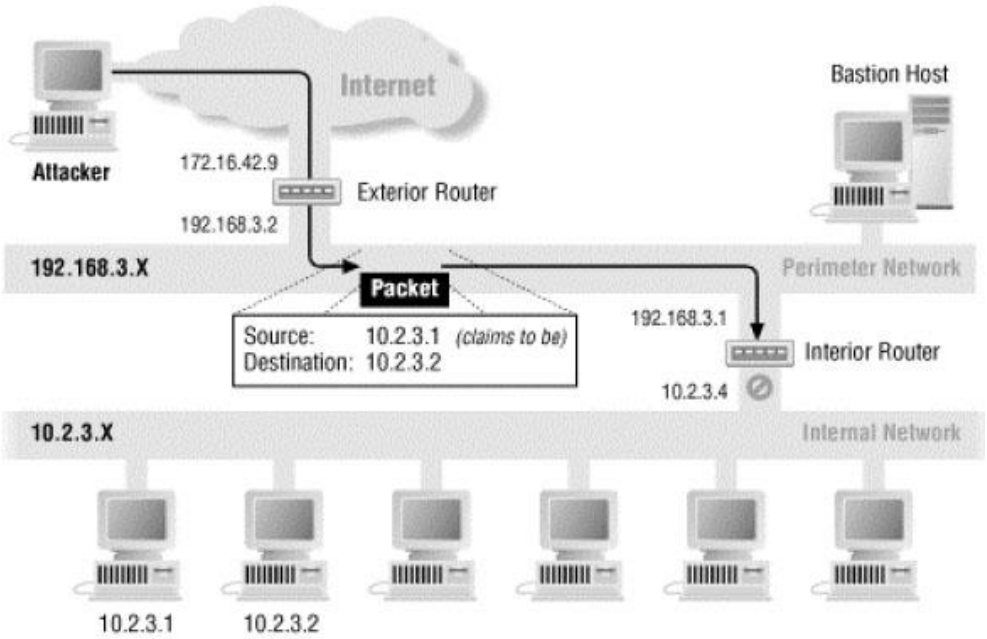


Рисунок 2 - Фільтруючі маршрутизатори (exterior/interior router) блокують пакети з підробленими адресами відправника

Найпростіші пакетні фільтри (або найпростіші правила фільтрації) здатні були контролювати трафік, спираючись на такі дані заголовка пакета:

– адреса відправника;
– адреса призначення;
– порт відправника;
– порт призначення.

Завдання простої системи можна виразити такими прикладами: „не пропускати з зовнішньої мережі пакети, якщо адреса відправника співпадає з адресами внутрішньої мережі”; „пропускати з зовнішньої мережі тільки пакети на SMTP-порт (25) певної адреси внутрішньої мережі”. Але за допомогою таких обмежених параметрів система не зможе виконати завдання дозволити підключення ззовні протоколом ssh для користувача з певним іменем, або не допустити передавання по FTP певних типів файлів: „ім‘я користувача” та „тип файла” не є предметом пакетної фільтрації. Взагалі система не здатна визначити, чи SSH-протокол застосований на порту 22.

Більш складна система фільтрації називається контекстною.

Контекстна фільтрація пакетів (Stateful Dynamic Packet Filtering) тримає в пам’яті суттєві атрибути кожного мережевого з’єднання: ip-адреси, номери портів, номер tcp-послідовності. З допомогою більшої кількості параметрів можна вирішити такі задачі (як приклад):

– приймати TCP-пакети ззовні лише якщо вони є частинами сегментів вже встановленої TCP-сесії (контроль за TCP sequence number);
– приймати ззовні UDP-пакети з порта 53 будь-якого хоста, якщо перед тип був вихідний пакет на порт 53 того ж хоста.

Приклад контролю UDP за допомогою контекстної фільтрації наведений на рис. 2.3.

Водночас із більшими можливостями, контекстна фільтрація ускладнює ПЗ маршрутизтора, збільшує його вразливість (складні алгоритми, обсяг даних що обробляються, легше утворення DoS) та збільшує ризик втрати частки легального трафіка (в разі втрати таблиць стану сесій через збій чи перезавантаження ПЗ маршрутизатора).

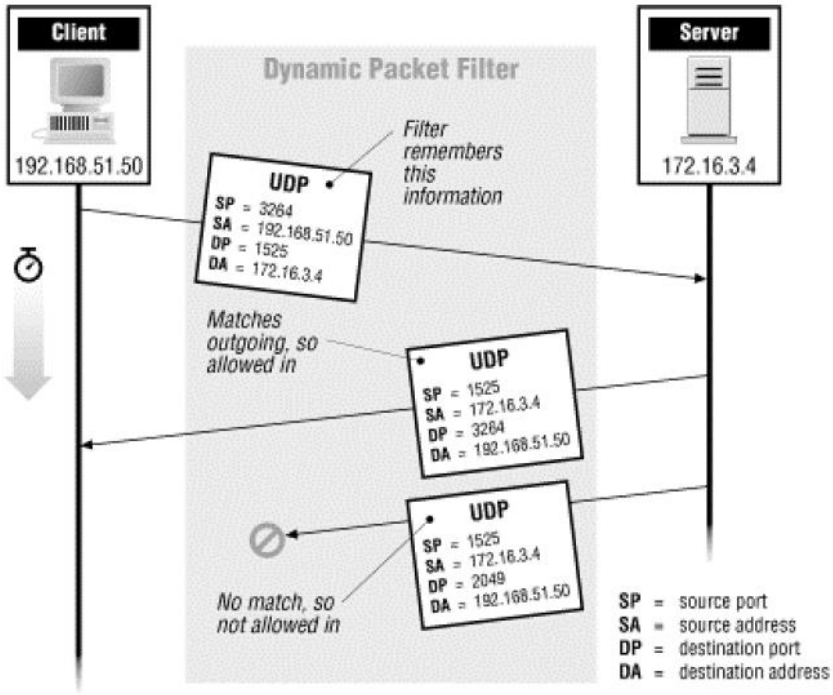


Рисунок 3 - Контроль UDP за допомогою контекстної фільтрації

І взагалі контекстний аналіз є шкідливим і майже неможливим, якщо трафік з зовнішньої до внутрішньої мережі може легально попадати через 2 чи більше шляхи (через те що майже жоден з сервісних протоколів Інтернет не потребує „симетрії” проходженні IP-пакетів між двома сторонами одного віртуального з‘єднання).

Найскладніші та найбільш функціонально повні системи здатні аналізувати протоколи застосувань, тому можуть вибірково дозволяти з‘єднання з веб-сайтами з певними іменами, передавати файли окремих типів, пропускати команди SMTP-протокола лише у певній послідовності тощо. Але пакетна фільтрація має бути часткою firewall.

Дії фільтра щодо пакетів можливі лише дві: дозволити (pass, allow, permit) або заборонити (deny, drop, block). Всі інші дії є додатками до двох основних. Серед таких додаткових дій є запис в журнал, повернення повідомлення ICMP, занести параметри пакета в таблицю станів тощо.

Ключовим моментом в складанні правил фільтрації є використання замовчання „все заборонено”. Цей стан (default deny stance) продиктований простою логікою, що заздалегідь кількість вад безпеки внутрішній мережі передбачити не можна. Тому цей стан в більшості випадків дозволяє оптимізувати (скоротити) кількість правил в конфігурації фільтрів.

Також для правильного використання фільтрації необхідно уявляти собі шлях пакета в маршрутизаторі (рис. 4).

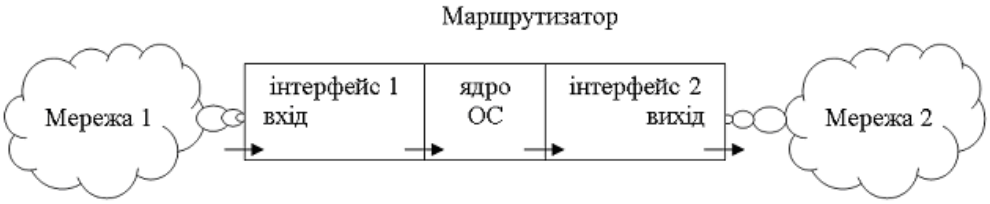


Рисунок 4 - Проходження IP-пакета через маршрутизатор

Конфігурування IP-фільтрів є завданням перекладання політики безпеки на мову TCP/IP. Наприклад, для рис. 2 завдання „приймати пошту з Інтернет лише на хост 192.168.3.3” для застосування в конфігурації IP-фільтрів маршрутизатора „Exterior Router” має бути перекладене так: „приймати пакети з будь якої адреси, якщо адреса отримувача – 192.168.3.3, при цьому порт отримувача 25, а протокол – TCP”. При виконанні перекладу не можна забувати, що більшість сервісів базується на двонаправлених протоколах, тому в нашому прикладі необхідно ще одне правило: „приймати пакети з адреси 192.168.3.3 на будь-яку адресу, якщо порт відпраника 25, а протокол – TCP”.

Розглянемо найтиповішу задачу фільтрації пакетів на базі мережі, що зображена на рис. 2, та задачі, сформульованої раніше: „приймати пошту з Інтернет лише на хост 192.168.3.3”. Формалізуємо її вигляді табл. 1.

Таблиця 1 - Формалізація правила фільтрації пакетів

№	Напрямок	Source IP	Порт	Destination IP	Порт	Протокол	Дія
1	вхід	будь-який	>1024	192.168.3.3	25	TCP	pass
2	вихід	192.168.3.3	25	будь-який	>1024	TCP	pass

Трансляція IP-адрес

Технологія ***трансляції мережевих адрес*** (Network Address Translation, NAT) дозволяє використовувати різні множини IP адрес у внутрішній мережі та при взаємодії із зовнішньою мережею. NAT сама по собі не несе ніяких функцій захисту, проте допомагає приховати топологію внутрішньої мережі та примусити з‘єднання йти виключно контрольованим шляхом.

NAT, як і фільтрація, є зазвичай ***функцією міжмережеввого екрана, встановленого на маршрутизаторі***. Але, на відміну від пакетних фільтрів, підчас трансляції адрес маршрутизатор вносить зміни до заголовка пакету. Коли клієнт внутрішньої мережі надсилає пакет до зовнішньої, NAT замінює адресу відправника на задану, і передає пакет в зовнішню мережу. Отримуючи пакет у відповідь, NAT виконує зворотну заміну (вже не відправника, а отримувача) та надсилає пакет у внутрішню мережу.

Теоретично, NAT може водночас переписувати дані і відправника, і отримувача, але зазвичай за допомогою NAT модифікують дані, що стосуються внутрішньої мережі.

Підчас трансляції зазвичай замінюється і адреса, і порт відправника, тому більш правильною назвою такої системи є Port and Network Address Translation (PNAT).

Щоб змусити клієнтів внутрішньої мережі використовувати виключно контрольований шлях, всі з‘єднання, що містять справжні адреси, краще технічно унеможливити (в тому числі за допомогою фільтрів).

Іншою важливою метою застосування NAT є економія „реальних” (глобально маршрутизованих) IP-адрес та використання у внутрішній мережі приватних адрес (RFC 1918).

Конфігурування NAT. Роздивимось основні способи трансляції адрес та портів на прикладі того ж IP Filter (конфігураційний файл у FreeBSD – /etc/ipnat.rules) та схеми на рис. 2. Припустимо, що завданням є дозволити на зовнішньому маршрутизаторі всі вихідні з‘єднання клієнтів внутрішньої мережі 10.2.3.0/24. Для цього „перепишемо” ці адреси в адресу зовнішнього інтерфейса маршрутизатора:

```
map if_ext 192.168.1.0/24 -> 0/32
```

Така універсальна конфігурація має вирішувати цю задачу. В цій конфігурації обробляються всі протоколи, змінюоеться IP адреса, номер порта зберігається. Якщо треба вказати, для яких протоколів застосовувати NAT:

```
map if_ext 10.2.3.0/24 -> 0/32 portmap tcp/udp auto
```

Можливі ситуації, коли бажано явно вказати в яку адресу переписувати, та який діапазон портів можна використовувати:

```
map if_ext 10.2.3.0/24 -> 172.16.42.9/32 portmap tcp/udp 20000:30000
```

Якщо з‘єднань між внутрішньою та зовнішньою мережею дуже багато (десятки тисяч), буде правильним використовувати NAT в блок адрес:

```
map if_ext 10.2.3.0/24 -> 172.16.42./24 portmap tcp/udp 20000:60000
```

Засобами NAT можливо забезпечити статичну трансляцію, коли внутрішня адреса завжди транслюється в одну й ту саму зовнішню:

```
map-block if_ext 10.2.3.0/24 -> 172.16.42./24 portmap tcp/udp 20000:60000
```

Також інколи NAT застосовується для статичної трансляції адреси/порта отримувача у вхідних пакетах з зовнішньої мережі, аби вони були адресовані певному внутрішньому хосту, при цьому для хоста забезпечується відповідна зворотня трансляція вихідних пакетів:

```
bimap tun0 192.168.1.1/32 -> 20.20.20.1/32
```

За допомогою NAT та сервіса “redirect” можна також вирішити дуже складні задачі по приховуванню та перерозподілу доступних сервісів у захищеній мережі.